Bài tập cá nhân 3 · VT-051

Sinh viên: Vũ Đình Hoàng · 23001881
Nhóm / đề tài: SE2026-T12 · APP-07 Reliable Event Ticketing với QR check-in
Repository canonical (sinh viên xác nhận): SE2026-30-2/reliable-event-ticketing
Ghi chú: đề bài ghi tên cũ Resilient-Order-Workflow
Baseline: `aa5ea7d8ef8da4e0472b7327c81e612b64337103`
Branch: assignment/BT3-23001881-VT-051
GitHub branch: https://github.com/SE2026-30-2/reliable-event-ticketing/tree/assignment/BT3-23001881-VT-051
Test commit: `4d189a7`
Phạm vi thực thi: characterization security test và concurrency harness trên module check-in; không triển khai workflow reviewer.

Cam kết: “Tôi chịu trách nhiệm về toàn bộ code, test và nội dung bài làm; tôi đã khai báo việc sử dụng AI.”

1. Specification

Problem statement. Cần cho một vai trò reviewer đọc và phê duyệt thay đổi mà không thể sửa dữ liệu gốc. Nếu hai yêu cầu cùng tác động một tài nguyên, hệ thống phải bảo toàn trạng thái hợp lệ và chỉ ghi nhận quyết định tương thích với invariant. Repository hiện chưa định nghĩa đối tượng “phê duyệt”, trạng thái review, hoặc liên kết reviewer với tài nguyên.

Acceptance criteria đề xuất

1. Reviewer được cấp quyền rõ ràng chỉ xem tài nguyên và dữ liệu cần để review; dữ liệu ngoài phạm vi vẫn bị từ chối.
2. Reviewer có thể ghi nhận quyết định approve/reject kèm actor và thời điểm; không sửa nội dung gốc.
3. Reviewer gọi bất kỳ lệnh sửa dữ liệu gốc nào nhận 403; use case ghi dữ liệu không được gọi.
4. Hai quyết định đồng thời trên cùng một review chỉ tạo một chuyển trạng thái hợp lệ; request còn lại nhận conflict/no-op được định nghĩa.
5. Thiếu/sai dữ liệu bắt buộc bị từ chối trước khi ghi; thao tác lỗi không để lại trạng thái dở dang.

Ràng buộc phi chức năng: 200 tác vụ đồng thời, p95 ≤ 5.0 giây; mọi quyết định phải có audit trail; không được nới quyền sửa hoặc thay đổi API/DB hiện hữu ngoài thiết kế được review.

Invariant trọng yếu: reviewer chỉ được ghi vào bản ghi quyết định/audit được chỉ định, tuyệt đối không thể sửa dữ liệu gốc; với cùng tài nguyên, không thể có hai quyết định xung đột được commit.

2. Kế hoạch AI và review dựa trên repo

Prompt kế hoạch: “Đọc repository APP-07 và đề xuất hai phương án tối thiểu cho reviewer chỉ đọc/phê duyệt, không sửa dữ liệu gốc. Nêu file, API/schema tác động, invariant, test concurrency, mutation bỏ validation, và không sửa code trước khi trình bày plan.”

Giả định: JWT `roles` là nguồn authority; phê duyệt cần lưu bền vững/audit; “tài nguyên” chưa xác định nên chưa thể thiết kế endpoint thực.

Phương án	Đánh giá repo / quyết định
A. Thêm ROLE_REVIEWER vào identity JWT và cho phép đọc trong ticketing; tạo workflow review mới với bảng/API.	Bị hoãn: repo không có đối tượng approval; cần đổi hai service, schema migration và API contract. Không tự ý chọn loại tài nguyên hay trạng thái.
B. Characterization trên authorization và concurrency check-in hiện có; ghi rõ thiếu workflow, không thay contract.	Chọn cho vertical slice kiểm thử: repo đã có `ManagementEndpointsSecurityTest`, atomic PostgreSQL check-in và `CheckinRecordConcurrencyIT`.

Ít nhất hai hiệu chỉnh plan: (1) Plan giả định role chỉ cần thêm trong `SecurityConfig`; bằng chứng `identity-service` ký JWT từ claim `roles`, còn ticketing chỉ chuyển claim thành authority, nên thêm role thật cần cả cấp role phía identity. (2) Plan gợi ý khóa lạc quan cho concurrency; repo check-in đã dùng advisory transaction lock và unique partial index theo `(ticket_id, entry_no)`, do đó harness phải kiểm tra database thật, không thay bằng Mockito. (3) Chưa thêm `approval` migration/API vì không có resource/state được yêu cầu đủ rõ.

File dự kiến đổi: hai test hiện hữu ở ticketing-platform; report và README dưới `docs/assignment/`. Không sửa production, migration, DTO, endpoint hay service identity.

3. Risk-based test strategy

ID	Risk / requirement	Level	Input / precondition	Kết quả mong đợi	Pri
T01	AC3: reviewer sửa event	API security	JWT REVIEWER, PATCH event	403; update use case không gọi	P0
T02	AC1: reviewer đọc tài nguyên trong scope	API / E2E	Reviewer hợp lệ, resource được giao	200, chỉ trường được phép	P1
T03	AC1: đọc ngoài scope	API	Reviewer đọc resource không giao	403 hoặc 404 theo policy, không lộ dữ liệu	P1
T04	AC2: ghi nhận quyết định	Integration/API	Review OPEN; approve hợp lệ	Quyết định + actor/time được lưu, resource gốc không đổi	P0
T05	AC3: negative write	API	Reviewer thử PATCH dữ liệu gốc	403; không có side effect	P0
T06	AC4: race approve/approve	Concurrency	Hai request cùng review id, start gate	Chỉ một commit; kết quả còn lại deterministic	P0
T07	AC4: race approve/reject	Concurrency	Hai quyết định xung đột cùng resource	Không thể commit đồng thời cả hai trạng thái	P0
T08	AC5: validation thiếu actor/decision	Unit/API negative	Thiếu decision hoặc reviewer id	400; không ghi audit/approval	P1
T09	Failure path: DB lỗi khi ghi audit	Integration	Ép lỗi insert audit trong transaction	Không có trạng thái nửa vời; lỗi được báo/log	P0
T10	Check-in analog: single-use race	Postgres concurrency IT	200 worker, cùng ticket, key riêng	Chính xác một ACCEPTED	P0
T11	Mutation: bỏ validity-window validation	Unit mutation	QR đã hết hạn, repository tryAccept stub ACCEPTED	EXPIRED_WINDOW; tryAccept không gọi	P0
T12	Multi-entry capacity	Postgres concurrency IT	10 worker, maxEntries=3	3 ACCEPTED; entry_no 1..3 không trùng/gap	P0

Phân tầng: unit kiểm validation/decision logic; API kiểm JWT authority, status và không gọi write use case; integration/Postgres kiểm atomicity và rollback; E2E chỉ cần khi workflow approval thật có UI. E2E hiện chưa cần vì chưa có endpoint/resource/role provisioning để đi xuyên hệ thống; viết E2E lúc này sẽ kiểm mock hoặc luồng không tồn tại. T02–T09 là test design cho workflow tương lai, chưa chạy và không được tính là coverage đạt.

Concurrency data: mọi worker dùng cùng ticket UUID để ép tranh chấp đúng một aggregate, nhưng idempotency key khác nhau để không đo nhầm duplicate retry; maxEntries=1 cho race single-use, rồi maxEntries=3 để xác nhận boundary nhiều lượt. Barrier đồng bộ bắt đầu giảm sai lệch do request chạy tuần tự.

Negative/failure: T01/T05/T08; failure path T09. T10/T11/T12 là các case chạy được trong repository gần nhất.

4. Test-first slice, mutation và evidence

Slice: characterization cho “reviewer không thể PATCH event hiện có” và mở rộng integration harness chống race check-in lên 200 worker. Đây không phải implementation của approval; change request đầy đủ cần xác định loại resource, ai giao review, state machine, quyền xem và audit retention.

Baseline: `aa5ea7d8ef8da4e0472b7327c81e612b64337103`. Branch local: `assignment/BT3-23001881-VT-051`.

Fail → patch → pass: mutation tạm thời xóa kiểm tra `validFromEpochSeconds/validUntilEpochSeconds` trong `SubmitCheckinApplicationService`. Lệnh `.\mvnw.cmd -B -ntp "-Dtest=SubmitCheckinApplicationServiceTest#rejectsATicketOutsideItsValidityWindow" test` fail: `expected EXPIRED_WINDOW but was ACCEPTED`. Mutation được khôi phục; chạy lại unit/API chọn lọc thành công: 20 tests, 0 failures/errors. Test đảm bảo `tryAccept` không được gọi cho QR hết hạn.

Integration: `.\mvnw.cmd -B -ntp "-Dtest=CheckinRecordConcurrencyIT" test` không chạy được: Testcontainers báo “Could not find a valid Docker environment”; Docker CLI không kết nối được pipe `dockerDesktopLinuxEngine`. Vì vậy chưa có kết quả 200 worker, chưa có p95 đo được. Không kết luận mục tiêu ≤5 giây đạt hay không đạt.

Toàn module: `.\mvnw.cmd -B -ntp verify` thành công: 177 tests, 0 failures/errors/skipped. Integration tests cần Docker không được chạy trong verify.

Patch được review: test reviewer PATCH kỳ vọng 403 và verify use case không gọi; harness dùng gate, UUID/key riêng, thời gian đơn đi tính p95. Không sửa production; pool luôn shutdown trong finally. File: `ManagementEndpointsSecurityTest`, `SubmitCheckinApplicationServiceTest`, `CheckinRecordConcurrencyIT`.

Coverage và độ tin cậy

JaCoCo không được cấu hình trong `pom.xml`, nên không có line/branch coverage đáng tin để báo. Risk coverage của slice: kiểm trực tiếp role không được phép sửa (đạt); mutation QR hết hạn bị bắt (đạt); atomic multi-entry và race 200 worker có test nhưng chưa chạy do Docker (chưa chứng minh); AC reviewer đọc/approve và audit chưa có implementation/test chạy (chưa đạt). Tỷ lệ line coverage không thể thay cho các kết luận theo risk này.

Flaky risks: (1) đua concurrency phụ thuộc tải máy/DB; giảm bằng gate, random UUID mỗi run, timeout 60s và không khẳng định p95 từ một lần chạy. (2) JUnit/DB shared state: dùng UUID mới cho mỗi case và truy vấn theo đúng ticket; không phụ thuộc test order. (3) Không có network/API ngoài trong harness; Docker/image pull vẫn là dependency môi trường.

5. Traceability và hai phương án

AC / risk	Test	Test file	Commit / kết quả
AC3 reviewer không sửa dữ liệu	T01	ManagementEndpointsSecurityTest	`4d189a7`; pass (HTTP 403, use case không gọi)
AC4 same-resource race	T10, T12	CheckinRecordConcurrencyIT	`4d189a7`; harness thêm 200 worker, chưa chạy do Docker daemon unavailable
AC5 bỏ validation thời gian QR	T11	SubmitCheckinApplicationServiceTest	`4d189a7`; mutation fail `ACCEPTED` vs `EXPIRED_WINDOW`; khôi phục và suite pass
Reviewer read/approve + audit	T02–T09	Chưa có test file	Chưa triển khai; thiếu resource/state contract và cấp role ở identity-service

Phương án chọn: B, characterization/harness. Bằng chứng: test security hiện hữu mock các use case nhưng đi qua Spring Security filter chain; repository có PostgreSQL advisory lock và unique partial index, cùng integration test thật đã có sẵn. Harness mới làm lộ evidence cụ thể mà không đo sai bằng mock.

Phương án loại/bác hoãn: A, thêm role và approval workflow end-to-end. `identity-service` owns user roles/JWT; ticketing maps claim `roles`; API docs hiện chỉ ADMIN/ORGANIZER/USER; không có `approval` entity/table/state. Chọn endpoint hay schema lúc này là tự phát minh business contract. Cần owner xác nhận resource, phân công reviewer, trạng thái quyết định, quyền đọc PII, audit và xử lý quyết định xung đột trước khi code.

Hai điểm AI-generated không được tin ngay

1. AI có thể nói “thêm ROLE_REVIEWER vào Spring Security là xong”; thực tế role phải được cấp/đưa vào JWT từ identity-service, và authorization theo từng resource vẫn cần kiểm tra ở ticketing.
2. AI có thể dùng Mockito/barrier rồi gọi đó là proof concurrency; test đó không chạy transaction, advisory lock hay unique index PostgreSQL. Chỉ test container thật mới xác minh được contract DB, và hiện môi trường chưa chạy được.

Performance: harness định đo thời gian từng thao tác từ lúc worker qua start gate đến lúc repository trả kết quả; p95 là phần tử thứ `ceil(0.95 × 200)` sau sort. Dữ liệu là một ticket, capacity 1, 200 key riêng. Đây chỉ là persistence contention, không mô phỏng HTTP, JWT, Kafka, network hoặc 200 người dùng khác nhau. Vì container không khởi động được nên không có số đo để so sánh với 5.0s.

6. Reflection (bản nháp, cần sinh viên rà soát)

Confidence tăng lên khi kết luận dựa vào hành vi chạy được thay vì đề xuất của AI. Security test đi qua Spring Security filter chain xác nhận authority REVIEWER không thể PATCH event; use case sửa dữ liệu không bị gọi. Mutation bỏ kiểm tra cửa sổ hiệu lực QR làm kết quả đổi từ EXPIRED_WINDOW thành ACCEPTED. Sau khi khôi phục validation, 20 test unit/API chạy xanh. Repository có advisory lock theo ticket và unique index cho entry_no, nên kiểm tra concurrency cần PostgreSQL thật, không chỉ mock. Tuy nhiên, Testcontainers không chạy vì Docker daemon không sẵn sàng; tôi chưa có p95 cho 200 tác vụ và không thể kết luận đạt mục tiêu 5 giây. Harness chỉ đo persistence, không gồm HTTP, JWT, Kafka, mạng hay hạ tầng triển khai. Change request reviewer cũng chưa được triển khai: repo chưa định nghĩa tài nguyên review, phân công, state machine approve/reject, quyền đọc dữ liệu nhạy cảm hoặc lưu audit. Chỉ thêm role có thể tạo quyền nửa vời; identity-service phát hành claim JWT, còn ticketing phải giới hạn dữ liệu theo phạm vi và chặn mọi đường sửa gốc. Bước tiếp theo giá trị nhất là chốt với product/giảng viên resource và trạng thái review, rồi viết API contract cùng test âm trước implementation. Khi Docker sẵn sàng, chạy CheckinRecordConcurrencyIT nhiều lần, ghi p95 và cấu hình máy, sau đó bổ sung HTTP load test 200 client trên endpoint approval thật. Cũng cần kiểm tra race approve/reject, rollback khi ghi audit lỗi và phân quyền đọc theo resource. Evidence hiện có xác nhận test bắt được một validation bị bỏ và reviewer bị chặn khỏi PATCH hiện hữu. Nó chưa chứng minh workflow approval, quyền đọc an toàn, atomicity PostgreSQL trong lần chạy này hay hiệu năng production. Tôi sẽ xem đó là giới hạn cần công khai, không suy diễn từ test pass.

Reflection khoảng 320 từ; bản nháp AI dựa trên evidence lần chạy này, sinh viên cần rà soát và chỉnh cho đúng trải nghiệm cá nhân.

Trạng thái phát hành

Repository canonical và branch link theo xác nhận của sinh viên. Branch riêng, không merge; chưa tạo PR để chờ nhóm review. Tên repository trong email đề bài (`Resilient-Order-Workflow`) khác tên remote hiện hành (`reliable-event-ticketing`).

Phụ lục A · AI Usage Log và evidence

Công cụ	Prompt / output dùng	Điều chỉnh / bác bỏ	Evidence
OpenAI Codex coding agent	Đọc đề VT-051 và repository; đề xuất hai phương án, assumptions, file và risk trước code. Output: chọn characterization harness vì workflow approval chưa tồn tại.	Bác phương án thêm role+API/schema ngay: cần quyết định contract và mở rộng identity-service. Bác mock-only concurrency proof; dùng IT đã có với PostgreSQL.	SecurityConfig, identity SecurityConfig, API docs, CheckinRecordRepositoryAdapter, CheckinRecordConcurrencyIT.
OpenAI Codex coding agent	Sinh patch test nhỏ: reviewer không PATCH event; concurrency harness đo 200 worker; tăng độ chính xác assertion validation.	Review diff: không đổi production/API/schema; bỏ import thừa; tryAccept được stub để mutation fail thành ACCEPTED thay vì NPE.	20 unit/API test pass; mutation test expected EXPIRED_WINDOW but was ACCEPTED; IT bị chặn do Docker.

Log lệnh

```
Baseline: aa5ea7d8ef8da4e0472b7327c81e612b64337103
PASS .\mvnw.cmd -B -ntp "-Dtest=ManagementEndpointsSecurityTest,SubmitCheckinApplicationServiceTest" test
       Tests run: 20, Failures: 0, Errors: 0, Skipped: 0
PASS .\mvnw.cmd -B -ntp verify
       Tests run: 177, Failures: 0, Errors: 0, Skipped: 0
MUTATION FAIL .\mvnw.cmd -B -ntp "-Dtest=SubmitCheckinApplicationServiceTest#rejectsATicketOutsideItsValidityWindow" test
       expected EXPIRED_WINDOW but was ACCEPTED
BLOCKED .\mvnw.cmd -B -ntp "-Dtest=CheckinRecordConcurrencyIT" test
       Could not find a valid Docker environment; dockerDesktopLinuxEngine pipe unavailable
Coverage: JaCoCo not configured. No p95 measurement obtained.
```

Artifact không tính vào giới hạn 8 trang nội dung chính theo yêu cầu đề bài. Nội dung và tên file phải được kiểm tra trước khi nộp.